

基于 Detours 技术的 Windows 系统行为监控实验

1. 实验目的

- 1、熟悉微软发布的 Detours（绕行道）技术，理解 Detours 挂钩系统 API 调用的原理；
- 2、了解基于 Detours 技术的无文件 Ring3 Rootkit 工具 R77，能够安装并使用 R77 隐藏 Windows 系统上的进程、文件、注册表项、网络连接。
- 3、基于 Detours 和 R77 开发一套 Windows 系统行为监控工具，能够开发记录当前系统的操作行为，例如文件操作、进程创建、注册表操作、网络连接等。

2. 实验原理

2.1. Detours（绕行道）技术

Detours 是微软发布的一个函数库，提供了简单、高效、稳定的 API 挂钩功能。Detours 可以用于在 ARM, ARM64, X86, X64 和 IA64 CPU 平台上，拦截应用程序中的 Win32 API 调用，比如添加调试功能、拦截特定的系统信息。Detours 的官方代码及文档详见 <https://www.microsoft.com/en-us/research/project/detours/Detours>。

Detours 提供的函数可以重写内存中的代码，将目标函数的前几个指令替换为无条件跳转指令，将 CPU 控制权转移到指定的 Detour 函数。Detours 还可以编辑二进制 DLL 文件的导入表，将任意数据段附加到现有二进制文件以及将 DLL 加载到新进程内存空间中。Detours 技术的实现过程如下：

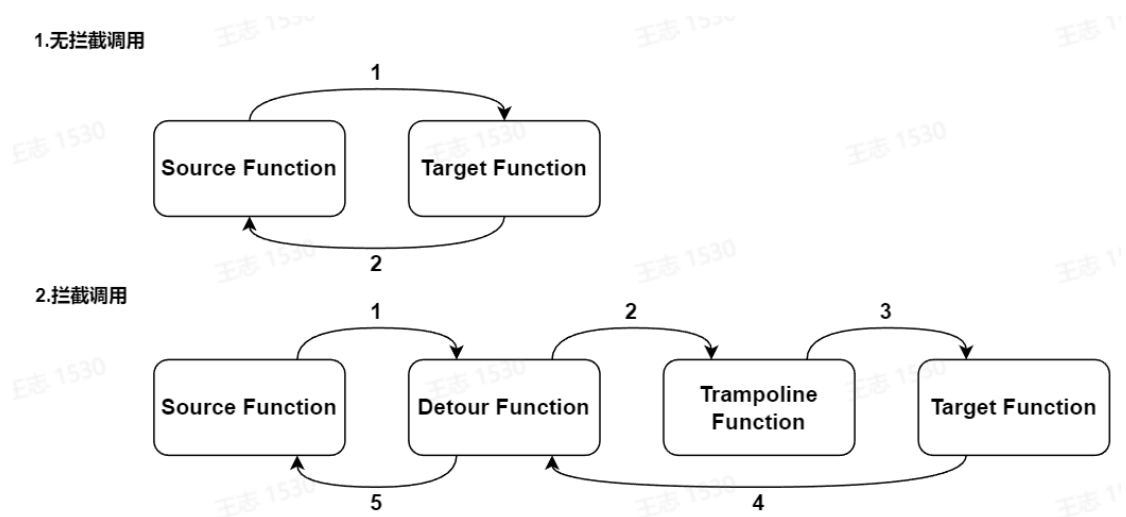


图 1 Detours 拦截函数调用流程

2.1.1 C++调用 Detours

要使用 C++调用 Detours 库，首先要对 Detours 库的源码进行编译，得到库文件。从代码仓库中下载源码，解压后 src 文件夹中即为需要编译的源码文件。

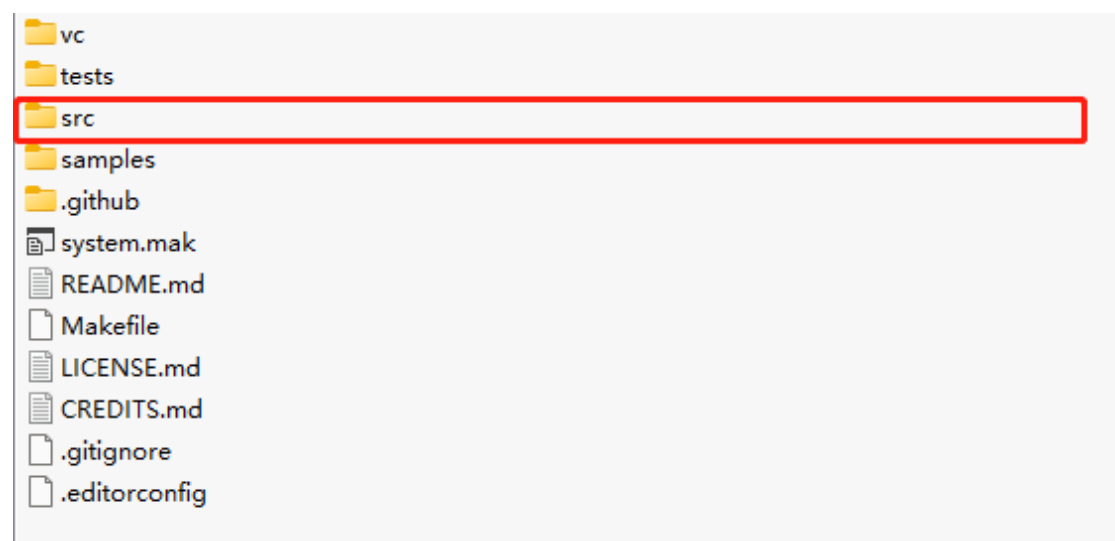


图 2 Detours 源码

1) 使用 nmake 命令编译

以 VS2019 环境为例，打开 VS 开发人员命令行窗口，进入 Detours 源码文件目录中的 src 目录，输入命令“nmake”进行编译。

```

D:\Downloads\Detours-main\Detours-main\src>nmake

Microsoft (R) 程序维护实用工具 14.20.27508.1 版
版权所有 (C) Microsoft Corporation。 保留所有权利。

Created ..\include
Created ..\lib.X64
Created ..\bin.X64
Created obj.X64
cl /nologo /W4 /WX /we4777 /we4800 /Zi /MT /Gy /Gm- /Z1 /Od /DDETOUR_DEBUG=0 /DWIN32_LEAN_AND_MEAN /D_WIN32_WINN
T=0x501 /Fd..\lib.X64\detours.pdb /Foobj.X64\ /c detours.cpp modules.cpp disasm.cpp image.cpp creatwth.cpp disolx86.cpp
disolx64.cpp disolia64.cpp disolarm.cpp disolarm64.cpp
detours.cpp
modules.cpp
disasm.cpp
image.cpp
creatwth.cpp
disolx86.cpp
disolx64.cpp
disolia64.cpp
disolarm.cpp
disolarm64.cpp
正在生成代码...
link /lib /out:..\lib.X64\detours.lib /nologo obj.X64\detours.obj obj.X64\modules.obj obj.X64\disasm.o
bj obj.X64\image.obj obj.X64\creatwth.obj obj.X64\disolx86.obj obj.X64\disolx64.obj obj.X64\dis
olia64.obj obj.X64\disolarm.obj obj.X64\disolarm64.obj
copy detours.h ..\include\detours.h
已复制 1 个文件。
copy detver.h ..\include\detver.h
已复制 1 个文件。
D:\Downloads\Detours-main\Detours-main\src>
```

图 3 nmake 指令编译

2) 导入库文件

将形成的 detours.h、detver.h 和 detours.lib 文件放入对应程序目录下，导入即可调用。

2.1.2 Detours 中的重要函数

1) DetourAttach

- 函数功能：截获目标函数。
- 函数定义：

```
LONG DetourAttach(
    _Inout_ PVOID * ppPointer,
    _In_     PVOID pDetour
);
```

- 参数：
 - ppPointer*：指向将要被截获函数地址的函数指针。
 - pDetour*：指向实际运行的函数的指针。
- 返回值：执行成功，则返回 **NO_ERROR**；否则，返回错误代码。

2) DetourDetach

- 函数功能：解除截获目标函数。

- 函数定义：

```
LONG DetourDetach(  
    _Inout_ PVOID * ppPointer,  
    _In_     PVOID pDetour  
);
```

- 参数：

ppPointer：指向将要被接触截获函数地址的函数指针。

pDetour：指向实际运行的函数的指针。

- 返回值：执行成功，则返回 NO_ERROR；否则，返回错误代码。

3) DetourTransactionBegin

- 函数功能：开始一次截获/解除截获。

- 函数定义：

```
LONG DetourTransactionBegin(VOID);
```

- 参数：无。

- 返回值：执行成功，则返回 NO_ERROR；否则，返回错误代码。

4) DetourUpdateThread

- 函数功能：列入一个在 Detour 事务过程中要更新的线程。

- 函数定义：

```
LONG DetourUpdateThread(  
    _In_ HANDLE hThread  
);
```

- 参数：

hThread：要用挂起的事务更新的线程的句柄。如果 *hThread* 等于当前线程伪句柄（由 GetCurrentThread（）返回），则不执行任何操作。

- 返回值：执行成功，则返回 NO_ERROR；否则，返回错误代码。

5) DetourTransactionCommit

- 函数功能：执行当前的捕获/解除捕获事务。
- 函数定义：

```
LONG DetourTransactionCommit(VOID);
```

- 参数：无。
- 返回值：执行成功，则返回 NO_ERROR；否则，返回错误代码。

2.2. R77 Rootkit 介绍

R77-Rootkit 是基于 Detours 技术开发的一款开源的功能强大的无文件 Ring3 Rootkit，并且带有完整的安全工具和持久化机制，可以实现进程、文件和网络连接等操作及任务的隐藏。R77 的源代码在 GitHub 上，下载地址为 <https://github.com/bytecode77/r77-rootkit>。R77 Rootkit 将所有以“\$77”为前缀命名的实体都将被隐藏，动态配置系统允许广大研究人员通过 PID 来隐藏进程，通过完整路径来隐藏文件系统，或通过指定端口隐藏 TCP&UDP 连接，如图 2 所示。

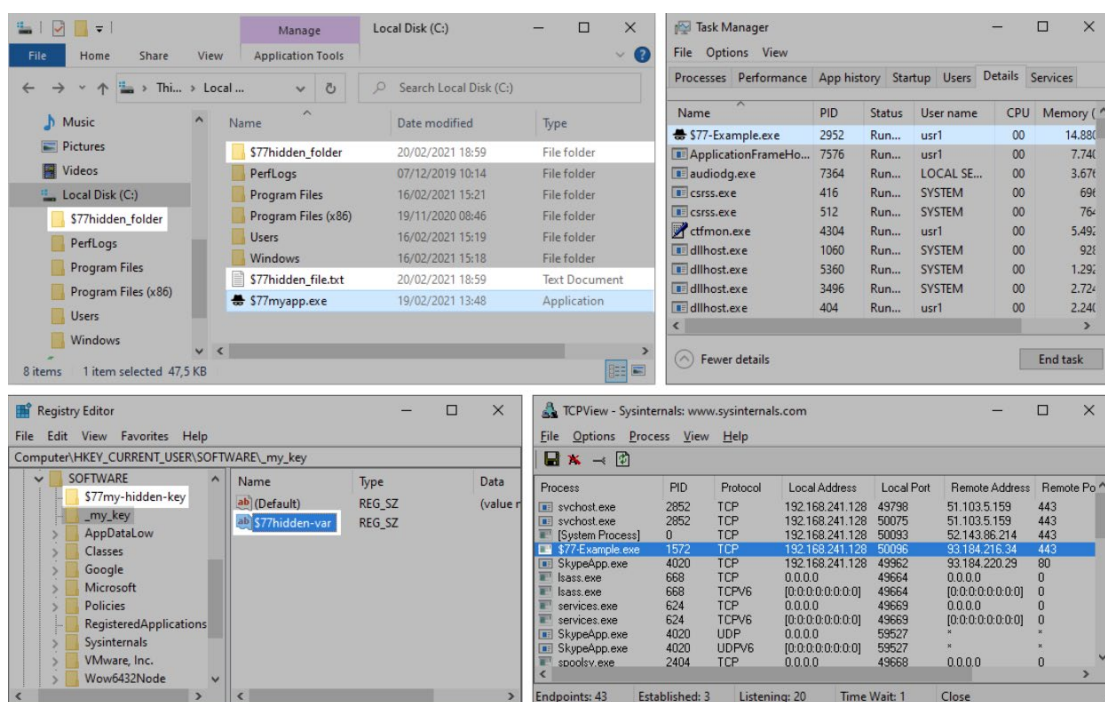


图 2 R77 Rootkit 隐藏系统文件、进程、注册表值、网络链接

2.2.1 R77 Rootkit 系统配置

R77 Rootkit 动态配置系统允许广大研究人员通过 PID 来隐藏进程，通过完整路径来隐藏文件系统，或通过指定端口隐藏 TCP&UDP 连接，如图 3 所示。配置信息存储在“HKEY_LOCAL_MACHINE\SOFTWARE\%77config”中，并且可以在未提权状态下由任何进程写入。这个键的 DACL 被设置为可以给任意用户授予完整访问权。“%77config”键在注册表编辑器被注入了 Rootkit 之后会自动隐藏。

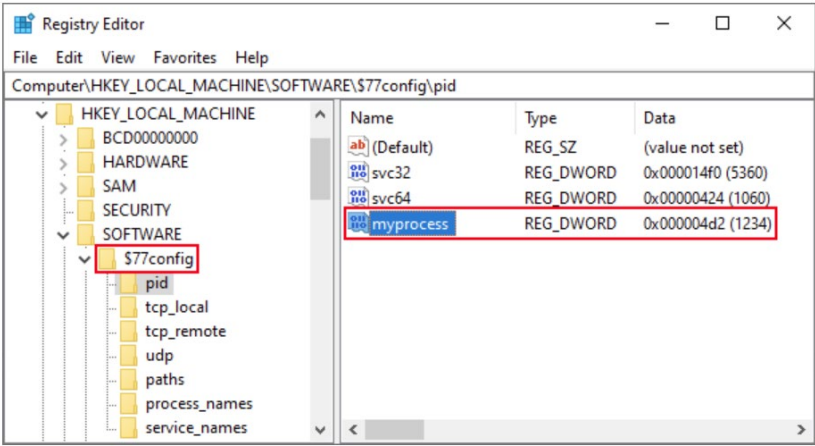


图 3 R77 Rootkit 配置

2.2.2 R77 Rootkit 的安装

R77 Rootkit 可以直接使用 GitHub 代码库中“Install.exe”进行安装，安装工具会将 R77 服务在用户登录之前开启，后台进程会向所有当前正在运行以及后续生成的进程中注入命令。这里需要使用两个进程来分别注入 32 位和 64 位进程，这两个进程都可以使用配置系统和 PID 来进行隐藏。“Uninstall.exe”程序负责将 r77 从系统中卸载掉，并解除 Rootkit 跟所有进程的绑定关系。

2.2.3. R77 无文件持久化

Rootkit 将驻留在系统内存中，不会将任何文件写入磁盘，这种机制是分多个阶段实现的。

(1) 阶段一

安装程序为 32 位和 64 位 r77 服务创建两个计划任务。计划任务确实需要存储名为\$77svc32.job 和\$77svc64.job 的文件，这是无文件概念的唯一例外。但是，一旦 Rootkit 运行，计划任务也会通过前缀隐藏，如图 4 所示。

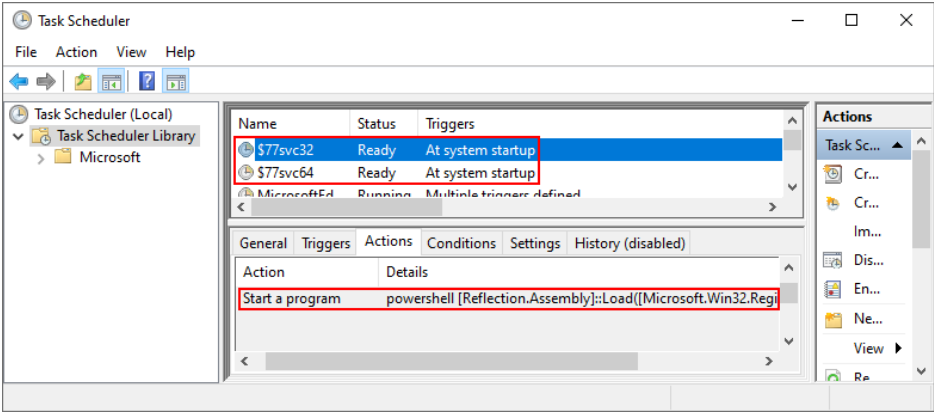


图 4 进程隐藏

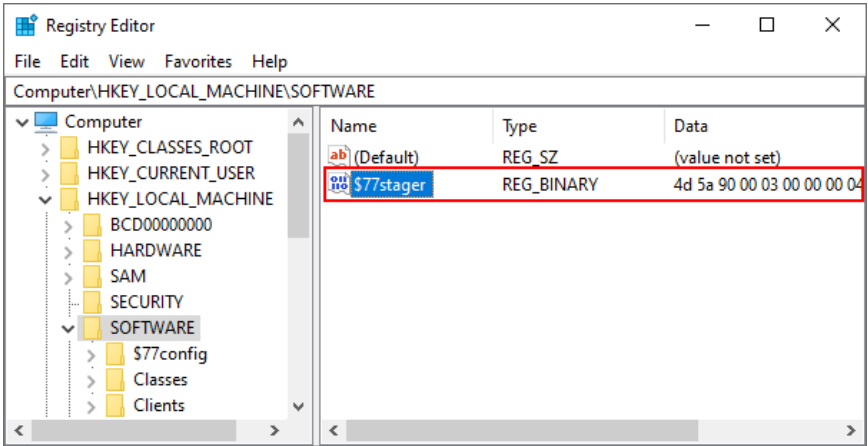


图 5 注册表修改

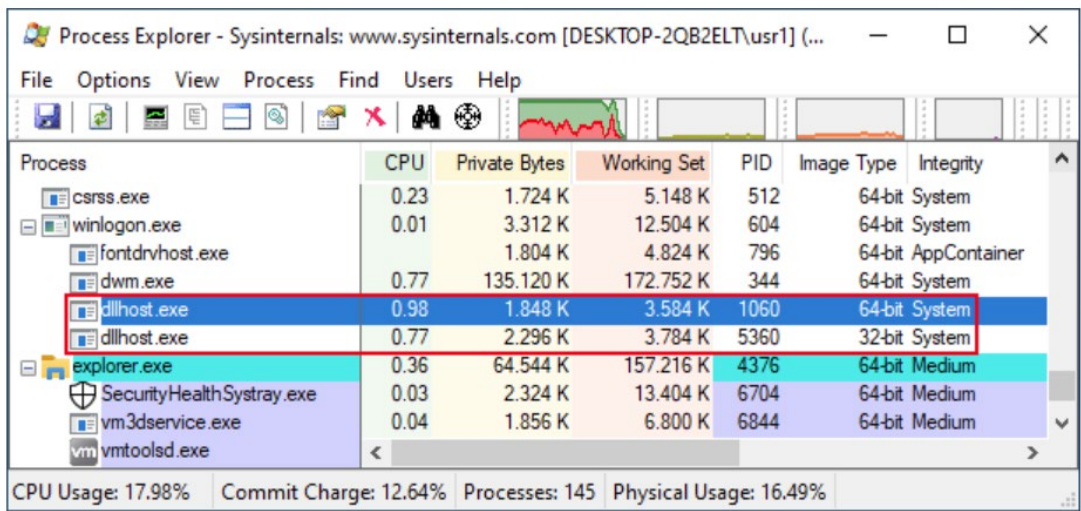
计划任务将使用下列命令开启“powershell.exe”：

```
[Reflection.Assembly]::Load([Microsoft.Win32.Registry]::LocalMachine.OpenSubkey('SOFTWARE').GetValue('$77stager').EntryPoint.Invoke($Null,$Null))
```

该命令是内联的，不需要.ps1 脚本。这里，使用 PowerShell 的 .NET Framework 功能从注册表加载 C#可执行文件并在内存中执行。由于命令行的最大长度为 260（MAX_PATH），因此只有足够的空间执行简单的 Assembly.Load().EntryPoint.Invoke()，如图 5 所示。

(2) 阶段二

执行的 C#代码为 stager，它将会使用 Process Hollowing 技术创建 R77 服务进程。R77 服务是一个本地可执行文件，分别以 32 位和 64 位架构分别编译。父进程被设置为了 winlogon.exe 以增加欺骗性（模糊性）。另外，这两个进程被 ID 隐藏，在任务管理器中不可见。磁盘上从未存储可执行文件或 DLL。stager 存储在注册表中，并从其资源加载 r77 服务可执行文件。



The screenshot shows the Process Explorer window from Sysinternals. The process list includes several system and user processes. Two instances of 'dllhost.exe' are highlighted with a red rectangle, indicating they are the R77 service processes. The first instance has PID 1060 and is a 64-bit System process. The second instance has PID 5360 and is a 32-bit System process. Other processes shown include csrss.exe, winlogon.exe, fontdrvhost.exe, dwm.exe, explorer.exe, SecurityHealthSystray.exe, vm3dservice.exe, and vmtoolsd.exe.

Process	CPU	Private Bytes	Working Set	PID	Image Type	Integrity
csrss.exe	0.23	1.724 K	5.148 K	512	64-bit System	
winlogon.exe	0.01	3.312 K	12.504 K	604	64-bit System	
fontdrvhost.exe		1.804 K	4.824 K	796	64-bit AppContainer	
dwm.exe	0.77	135.120 K	172.752 K	344	64-bit System	
dllhost.exe	0.98	1.848 K	3.584 K	1060	64-bit System	
dllhost.exe	0.77	2.296 K	3.784 K	5360	32-bit System	
explorer.exe	0.36	64.544 K	157.216 K	4376	64-bit Medium	
SecurityHealthSystray.exe	0.03	2.324 K	13.404 K	6704	64-bit Medium	
vm3dservice.exe	0.04	1.856 K	6.800 K	6844	64-bit Medium	
vmtoolsd.exe						

CPU Usage: 17.98% Commit Charge: 12.64% Processes: 145 Physical Usage: 16.49%

图 6 进程隐藏

R77 测试控制台可以用来向单独进程注入 r77，或接触进程跟 Rootkit 的绑定关系。

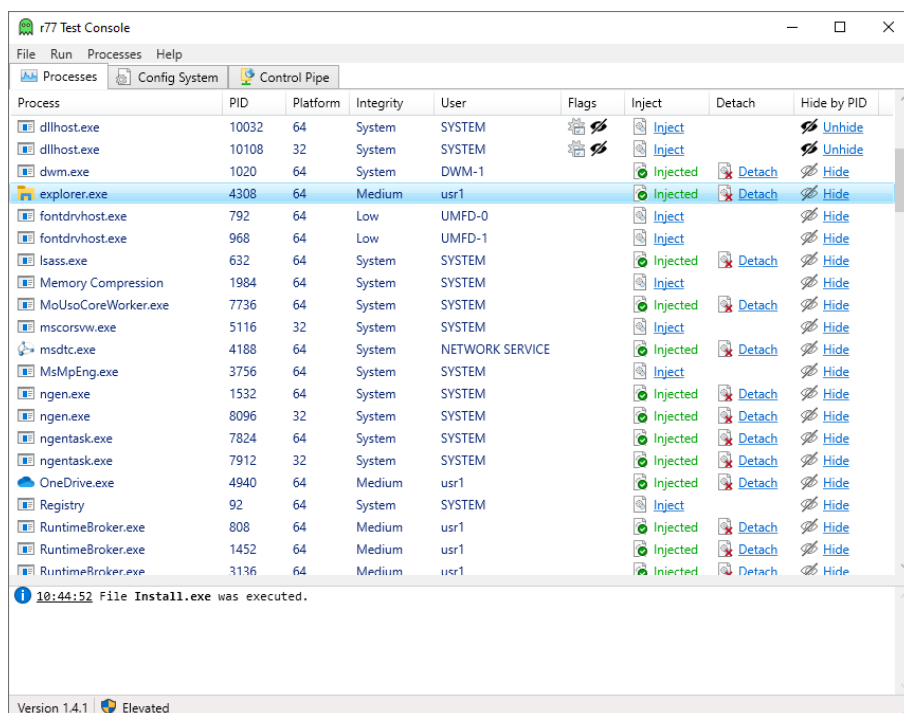


图 7 R77 测试控制台

3. 实验环境

Windows 操作系统，Detours 函数库，R77 Rootkit 工具源代码。R77 工具下载地址：<https://downloads.bytecode77.com/r77Rootkit%201.4.2.zip>（解压密码：bytecode77）。R77 的技术文档下载地址：<https://docs.bytecode77.com/r77-rootkit/Technical%20Documentation.pdf>

4. 实验内容

- （1）使用 Detours 库，实现对 Windows API 函数进行挂钩 Hook，不影响函数的正常执行，将 API 函数调用的参数输出到文件中；
- （2）安装并使用 R77 Rootkit 工具，隐藏系统的文件、进程、注册表项、网络链接；
- （3）基于 Detours 和 R77 开发一套 Windows 系统的行为监控工具，能够至少记录当前系统的一类操作行为，例如文件操作监控工具、进程创建监控工具、注册表操作监控工具、网络连接监控工具等等。

5. 实验报告

- (1) 基于 Detours 库的 API 函数挂钩实验报告；
- (2) 基于 R77 Rootkit 工具的系统信息隐藏实验报告；
- (3) 基于 Detours 和 R77 Rootkit 的 Windows 行为监控工具编写实验报告。